# Extração estruturada de vulnerabilidades a partir de relatórios de scanners de segurança

Beatriz Roland Machado
*Universidade Federal do Pampa (UNIPAMPA)*

Inteligência Artificial Aplicada – Atividade 2: investigação e viabilidade técnica

## 1. Problema e aplicação

Scanners de vulnerabilidade entregam seus achados em relatórios PDF, um formato por ferramenta, feitos para leitura humana. Os afetados são as equipes que os operam, tipicamente CSIRTs: sem dado estruturado, consolidar varreduras, comparar execuções e priorizar é trabalho manual de leitura. A tarefa de IA é extração de informação estruturada: o modelo recebe blocos delimitados e identificados mais o esquema JSON alvo, e devolve um item por bloco.

Uma abordagem por regras será o baseline, mas não basta: os campos tabulares saem por expressões regulares do cabeçalho do bloco, mas os narrativos são parágrafos cuja estrutura muda a cada scanner e a cada achado. A revisão em relação à proposta inicial é o recorte de **onde o modelo roda**: o relatório descreve a superfície de ataque da organização, e enviá-lo à nuvem o transfere a um terceiro, o que colide com o dever de proteger a infraestrutura que trata dados pessoais [Brasil 2018, art. 46]. Daí a pergunta do projeto: modelos pequenos, em uma GPU dentro da organização, dão conta da tarefa?

## 2. Dados

O conjunto vem de varreduras de aplicações reconhecidamente vulneráveis (OWASP Juice Shop, bWAPP, WackoPicko, WordPress e Drupal antigos). Cada relatório é um par: o PDF, entrada do sistema, e a exportação de máquina do mesmo scanner, que serve de gabarito. São 136 relatórios e 6.841 exemplos, 6.187 de treino e 654 de validação. **Os rótulos não são anotados à mão**: vêm da ferramenta que gerou o PDF, o que elimina o custo e a subjetividade da anotação manual. O pareamento usa host e nome do NVT no OpenVAS, host e QID no Qualys, host e plugin id no Nessus e nome do alerta no ZAP.

Três problemas de qualidade foram identificados. O **desbalanceamento** é forte, com o OpenVAS em cerca de 80% dos exemplos, tratado reportando por scanner. A **fidelidade à entrada** exige cuidado: a exportação às vezes traz texto que o PDF não imprime, e treinar nele ensina o modelo a alucinar, de modo que esses parágrafos saem do rótulo e do gabarito. O **vazamento** é evitado separando treino e teste por aplicação, não por arquivo.

## 3. Abordagem de IA

A técnica escolhida é um modelo generativo decodificando sob restrição de esquema JSON, em vez de rotulagem de sequência, porque a saída não é um recorte do texto: solução e impacto exigem reescrever o bloco, e a severidade exige mapear vocabulários distintos para um conjunto único. Além do baseline por regras, serão comparados um modelo de nuvem *few-shot*, como teto de referência, um modelo pequeno local de 4B a 21B também *few-shot*, e o mesmo modelo local ajustado com QLoRA em 4 bits

[Dettmers et al. 2023]. Requisitos: GPU com 16 GB de VRAM e de uma a duas horas de treino por modelo de 1,5B.

## 4. Trabalhos relacionados

Trabalhos recentes aplicam LLMs a extração estruturada em domínios próximos, sempre com um único modelo e sem comparar local com nuvem. Rahman et al. (2024) mapeiam CTI para técnicas ATT&CK com encoder local e Yang et al. (2026) constroem grafos de conhecimento a partir de CTI, só em nuvem; Wiest et al. (2023), em texto médico, e Keltek et al. (2024), em código-fonte, rodam só localmente por imposição do domínio; e Machado et al. (2025) extraem registros de relatórios de scanner com cinco modelos, só em nuvem.

Duas limitações se repetem: os trabalhos locais nunca medem o custo dessa escolha, e avaliar um único modelo impede separar limite da abordagem de limite do modelo. A diferença da proposta é tratar local ou nuvem como variável experimental, sobre a mesma tarefa e o mesmo pipeline, com dez modelos.

## 5. Desenvolvimento, avaliação e viabilidade

A arquitetura é um pipeline fixo com o modelo como peça trocável: PDF, texto, segmentação em blocos, empacotamento por orçamento de tokens, chamada ao modelo com esquema, consolidação e registros. O menor protótipo funcional é esse caminho completo para um scanner, com um modelo local. A avaliação separa cobertura, se cada achado virou um registro sem omissão nem invenção, de conteúdo, medido campo a campo contra o gabarito.

O projeto é viável com o que já existe: relatórios e gabaritos coletados, GPU acessível e treino da ordem de duas horas. O maior risco é de gabarito: onde a exportação não traz um campo que o PDF mostra, o modelo é penalizado por acertar, e a mitigação é auditar cada campo antes de usá-lo como métrica.

## 6. Uso da IA na investigação

As ferramentas foram ChatGPT e Claude, para discussão e crítica, e Claude Code sobre o repositório, para levantar números dos artefatos e redigir o texto. O levantamento de trabalhos relacionados partiu de `"Quais trabalhos usam LLM para extrair informação estruturada de texto de segurança? Em quais deles o modelo roda localmente?"`. Foram incorporadas duas contribuições: tratar local ou nuvem como variável experimental e separar a avaliação em cobertura e conteúdo. Foi descartada a sugestão de usar um LLM como juiz da saída, dispensável havendo gabarito de máquina. Os números saíram dos artefatos do projeto, não do modelo.

## Referências


BRASIL (2018). Lei nº 13.709, Lei Geral de Proteção de Dados Pessoais, art. 46.

DETTMERS, T. et al. (2023). QLoRA: Efficient Finetuning of Quantized LLMs.

KELTEK, M. et al. (2024). Análise estática de código com LLM local.

MACHADO, B. R. et al. (2025). Extração de vulnerabilidades de relatórios com LLMs.

RAHMAN, M. R. et al. (2024). Mapeamento de CTI para técnicas ATT&CK.

WIEST, I. C. et al. (2023). Extração estruturada de texto médico.

YANG, Z. et al. (2026). Grafo de conhecimento a partir de CTI com LLM.